

Information privacy, data privacy or data protection laws provide a legal framework on how to obtain, use and store data of natural persons. The various laws around the world describe the rights of natural persons to control who is using their data. This includes usually the right to get details on which data is stored, for what purpose and to request the deletion in case the purpose is not given anymore.

Over 80 countries and independent territories, including nearly every country in Europe and many in Latin America and the Caribbean, Asia, and Africa, have now adopted comprehensive data protection laws. The European Union has the General Data Protection Regulation (GDPR), in force since May 25, 2018. The United States is notable for not having adopted a comprehensive information privacy law, but rather having adopted limited sectoral laws in some areas like the California Consumer Privacy Act (CCPA).

By Jurisdiction

The German state of Hesse enacted the world's first data privacy law on September 30, 1970. In Germany the term informational self-determination was first used in the context of a German constitutional ruling relating to personal information collected during the 1983 census.

Asia

India

India passed its Digital Personal Data Protection Act, 2023 in August 2023.

China

China passed its Personal Information Protection Law (PIPL) in mid-2021, and was effective from November 1, 2021. It focuses heavily on consent, rights of the individual, and transparency of data processing. PIPL has been compared to the EU GDPR as it has similar

scope and many similar provisions.

Philippines

In the Philippines, The Data Privacy Act of 2012 mandated the creation of the National Privacy Commission that would monitor and maintain policies that involve information privacy and personal data protection in the country. Modeled after the EU Data Protection Directive and the Asia-Pacific Economic Cooperation (APEC) Privacy Framework, the independent body would ensure compliance of the country with international standards set for data protection. The law requires government and private organizations composed of at least 250 employees or those which have access to the personal and identifiable information of at least 1000 people to appoint a Data Protection Officer that would assist in regulating the management of personal information in such entities.

In summary, the law identifies important points regarding the handling of personal information as follows:

Personal information must be collected for reasons that are specified, legitimate, and reasonable.

Personal information must be handled properly. Information must be kept accurate and relevant, used only for the stated purposes, and retained only for as long as reasonably needed. The law required entities to be active in ensuring that unauthorized parties do not have access to their customers' information.

Personal information must be disposed in way that unauthorized third parties could not access the discarded data.

Sri Lanka

In early 2022, Sri Lanka became the first country in South Asia to enact comprehensive data

privacy legislation. The Personal Data Protection Act No. 9 of 2022, effective since March 19, 2022, applies to processing within Sri Lanka and extends extraterritorially to controllers or processors offering goods and services to individuals in Sri Lanka and/or monitoring their behavior in the country.

Europe

The right to data privacy is relatively heavily regulated and actively enforced in Europe. Article 8 of the European Convention on Human Rights (ECHR) provides a right to respect for one's "private and family life, his home and his correspondence", subject to certain restrictions. The European Court of Human Rights has given this article a very broad interpretation in its jurisprudence. According to the Court's case law the collection of information by officials of the state about an individual without their consent always falls within the scope of Article 8. Thus, gathering information for the official census, recording fingerprints and photographs in a police register, collecting medical data or details of personal expenditures, and implementing a system of personal identification has been judged to raise data privacy issues. What also falls under "privacy-sensitive data" under the GDPR is such information as racial or ethnic origin, political opinions, religious or philosophical beliefs and information regarding a person's sex life or sexual orientation.

Any state interference with a person's privacy is only acceptable for the Court if three conditions are fulfilled:

The interference is in accordance with the law

The interference pursues a legitimate goal

The interference is necessary in a democratic society

The government is not the only entity which may pose a threat to data privacy. Other citizens, and private companies most importantly, may also engage in threatening activities, especially

since the automated processing of data became widespread. The Convention for the Protection of Individuals with regard to Automatic Processing of Personal Data was concluded within the Council of Europe in 1981. This convention obliges the signatories to enact legislation concerning the automatic processing of personal data, which many duly did.

As all the member states of the European Union are also signatories of the European Convention on Human Rights and the Convention for the Protection of Individuals with regard to Automatic Processing of Personal Data, the European Commission was concerned that diverging data protection legislation would emerge and impede the free flow of data within the EU zone. Therefore, the European Commission decided to propose harmonizing data protection law within the EU. The resulting Data Protection Directive was adopted by the European Parliament and ministers from national governments in 1995 and had to be transposed into national law by the end of 1998.

The directive contains a number of key principles with which member states must comply. Anyone processing personal data must comply with the eight enforceable principles of good practice. They state that the data must be:

Fairly and lawfully processed.

Processed for limited purposes.

Adequate, relevant and not excessive.

Accurate.

Kept no longer than necessary.

Processed in accordance with the data subject's rights.

Secure.

Transferred only to countries with adequate protection.

Personal data covers both facts and opinions about the individual. It also includes information regarding the intentions of the data controller towards the individual, although in some

limited circumstances exemptions will apply. With processing, the definition is far wider than before. For example, it incorporates the concepts of "obtaining", "holding" and "disclosing". All EU member states adopted legislation pursuant this directive or adapted their existing laws. Each country also has its own supervisory authority to monitor the level of protection. Because of this, in theory the transfer of personal information from the EU to the US is prohibited when equivalent privacy protection is not in place in the US. American companies that would work with EU data must comply with the Safe Harbour Archived 2010-06-09 at the Wayback Machine framework. The core principles of data protected are limited collection, consent of the subject, accuracy, integrity, security, subject right of review and deletion. As a result, customers of international organizations such as Amazon and eBay in the EU have the ability to review and delete information, while Americans do not. In the United States the equivalent guiding philosophy is the Code of Fair Information Practice (FIP).

The difference in language here is important: in the United States the debate is about privacy where in the European Community the debate is on data protection. Moving the debate from privacy to data protection is seen by some philosophers as a mechanism for moving forward in the practical realm while not requiring agreement on fundamental questions about the nature of privacy.

France

France adapted its existing law, "no. 78-17 of 6 January 1978 concerning information technology, files and civil liberties".

Germany

In Germany, both the federal government and the states enacted legislation.

Switzerland

While Switzerland is not a member of the European Union (EU) or of the European Economic Area (EEA), it has partially implemented the EU Directive on the protection of personal data in 2006 by acceding to the STE 108 agreement of the Council of Europe and a corresponding amendment of the federal Data Protection Act. However, Swiss law imposes less restrictions upon data processing than the Directive in several respects.

In Switzerland, the right to privacy is guaranteed in article 13 of the Swiss Federal Constitution. The Swiss Federal Data Protection Act (DPA) and the Swiss Federal Data Protection Ordinance (DPO) entered into force on July 1, 1993. The latest amendments of the DPA and the DPO entered into force on January 1, 2008.

The DPA applies to the processing of personal data by private persons and federal government agencies. Unlike the data protection legislation of many other countries, the DPA protects both personal data pertaining to natural persons and legal entities.

The Swiss Federal Data Protection and Information Commissioner in particular supervises compliance of the federal government agencies with the DPA, provides advice to private persons on data protection, conducts investigations and makes recommendations concerning data protection practices.

Some data files must be registered with the Swiss Federal Data Protection and Information Commissioner before they are created. In the case of a transfer of personal data outside of Switzerland, special requirements need to be met and, depending on the circumstances, the Swiss Federal Data Protection and Information Commissioner must be informed before the transfer is made.

Most Swiss cantons have enacted their own data protection laws regulating the processing of personal data by cantonal and municipal bodies.

United Kingdom

In the United Kingdom the Data Protection Act 1998 (c 29) (Information Commissioner)

implemented the EU Directive on the protection of personal data . It replaced the Data Protection Act 1984 (c 35). The 2016 General Data Protection Regulation supersedes previous Protection Acts. The Data Protection Act 2018 (c 12) updates data protection laws in the UK. It is a national law which complements the European Union's General Data Protection Regulation (GDPR).

North America

Canada

In Canada, the Personal Information Protection and Electronic Documents Act (PIPEDA) went into effect on 1 January 2001, applicable to private bodies which are federally regulated. All other organizations were included on 1 January 2004. The PIPEDA brought Canada into compliance with EU data protection law, although civil society, regulators, and academics have claimed that it does not address modern challenges of privacy law as well as the GDPR does, calling for reform.

The PIPEDA specifies the rules to govern collection, use, or disclosure of the personal information in the course of recognizing the right of privacy of individuals with respect to their personal information. It also specifies the rules for the organizations to collect, use, and disclose personal information.

The PIPEDA applies to:

The organizations collect, uses, or disclosure in the matter of commercial use.

The organizations and the employee of the organization collect, use, or discloses in the course of operation of a federal work, undertaking, or business.

The PIPEDA does not apply to:

Government institutions to which the Privacy Act applies.

Individuals who collect, use, or disclose personal information for personal purpose and use.

Organizations which collect, use, or disclose personal information only for journalistic, artistic or literary purposes.

As specified in the PIPEDA:

"Personal Information" means information about an identifiable individual, but does not include the name, title, or business address or telephone number of an employee of an organization.

"Organization" means an association, a partnership, a person and a trade union.

"Federal work, undertaking or business" means any work, undertaking or business that is within the legislative authority of Parliament, including:

a work, undertaking or business that is operated or carried on for or in connection with navigation and shipping, whether inland or maritime, including the operation of ships and transportation by ship anywhere in Canada;

a railway, canal, telegraph or other work or undertaking that connects a province with another province, or that extends beyond the limits of a province;

a line of ships that connects a province with another province, or that extends beyond the limits of a province;

a ferry between a province and another province or between a province and a country other than Canada;

aerodromes, aircraft or a line of air transportation;

a radio broadcasting station;

a bank;

a work that, although wholly situated within a province, is before or after its execution declared by Parliament to be for the general advantage of Canada or for the advantage of two or more provinces;

a work, undertaking or business outside the exclusive legislative authority of the legislatures of the provinces; and

a work, undertaking or business to which federal laws, within the meaning of section 2 of the Oceans Act, apply under section 20 of that Act and any regulations made under paragraph 26(1)(k) of that Act.

The PIPEDA gives individuals the right to:

understand the reasons why organizations collect, use, or disclose personal information.

expect organizations to collect, use or disclose personal information in a reasonable and appropriate way.

understand who in the organizations pays the responsibility for protecting individuals' personal information.

expect organizations to protect the personal information in a reasonable and secure way.

expect the personal information held by the organizations to be accurate, complete, and up-to-date.

have the access to their personal information and ask for any corrections or have the right to make complain towards the organizations.

The PIPEDA requires organizations to:

obtain consent before they collect, use, and disclose any personal information.

collect personal information in a reasonable, appropriate, and lawful ways.

establish personal information policies that are clear, reasonable, and ready to protect individuals' person information.

United States

Data privacy is not highly legislated or regulated in the U.S. In the United States, access to

private data contained in, for example, third-party credit reports may be sought when seeking employment or medical care, or making automobile, housing, or other purchases on credit terms. Although partial regulations exist, there is no all-encompassing law regulating the acquisition, storage, or use of personal data in the U.S. In general terms, in the U.S., whoever can be troubled to key in the data, is deemed to own the right to store and use it, even if the data was collected without permission, except to any extent regulated by laws and rules such as the federal Communications Act's provisions, and implementing rules from the Federal Communications Commission, regulating use of customer proprietary network information (CPNI). For instance, the Health Insurance Portability and Accountability Act of 1996 (HIPAA), the Children's Online Privacy Protection Act of 1998 (COPPA), and the Fair and Accurate Credit Transactions Act of 2003 (FACTA), are all examples of U.S. federal laws with provisions which tend to promote information flow efficiencies.

The Supreme Court interpreted the Constitution to grant a right of privacy to individuals in *Griswold v. Connecticut*. Very few states, however, recognize an individual's right to privacy, a notable exception being California. An inalienable right to privacy is enshrined in the California Constitution's article 1, section 1, and the California legislature has enacted several pieces of legislation aimed at protecting this right. The California Online Privacy Protection Act (OPPA) of 2003 requires operators of commercial web sites or online services that collect personal information on California residents through a web site to conspicuously post a privacy policy on the site and to comply with its policy.

An early attempt to create rules around the use of information in the U.S. was the fair information practice guidelines developed by the Department for Health, Education and Welfare (HEW) (later renamed Department of Health & Human Services (HHS)), by a Special Advisory Committee on Automated Personal Data Systems, under the chairmanship of computer pioneer and privacy pioneer Willis H. Ware. The report submitted by the Chair to the HHS Secretary titled "Records, Computers and Rights of Citizens (07/01/1973)", proposes

universal principles for the privacy and protection of consumer and citizen data:

For all data collected, there should be a stated purpose.

Information collected from an individual cannot be disclosed to other organizations or individuals unless specifically authorized by law or by consent of the individual.

Records kept on an individual should be accurate and up to date.

There should be mechanisms for individuals to review data about them, to ensure accuracy. This may include periodic reporting.

Data should be deleted when it is no longer needed for the stated purpose.

Transmission of personal information to locations where "equivalent" personal data protection cannot be assured is prohibited.

Some data is too sensitive to be collected, unless there are extreme circumstances (e.g., sexual orientation, religion).

The safe harbor arrangement was developed by the United States Department of Commerce in order to provide a means for U.S. companies to demonstrate compliance with European Commission directives and thus to simplify relations between them and European businesses.

HIPAA

The Health Insurance Portability and Accountability Act (HIPAA) was enacted by the U.S. Congress in 1996. HIPAA is also known as the Kennedy-Kassebaum Health Insurance Portability and Accountability Act (HIPAA-Public Law 104-191), effective August 21, 1996. The basic idea of HIPAA is that an individual who is a subject of individually identifiable health information should have:

Established procedures for the exercise of individual health information privacy rights.

The use and disclosure of individual health information should be authorized or required.

One difficulty with HIPAA is that there must be a mechanism to authenticate the patient who demands access to his/her data. As a result, medical facilities have begun to ask for Social Security Numbers from patients, thus arguably decreasing privacy by simplifying the act of correlating health records with other records. The issue of consent is problematic under HIPAA, because the medical providers simply make care contingent upon agreeing to the privacy standards in practice.

FCRA

The Fair Credit Reporting Act applies the principles of the Code of Fair Information Practice to credit reporting agencies. The FCRA allows individuals to opt out of unwanted credit offers:

Equifax (888) 567-8688 Equifax Options, P.O. Box 740123 Atlanta GA 30374-0123.

Experian (800) 353-0809 or (888) 5OPTOUT P.O. Box 919, Allen, TX 75013

TransUnion (800) 680-7293 or (888) 5OPTOUT P.O. Box 97328, Jackson, MS 39238.

Because of the Fair and Accurate Credit Transactions Act, each person can obtain a free annual credit report.

The Fair Credit Reporting Act has been effective in preventing the proliferation of specious so-called private credit guides. Before 1970, private credit guides offered detailed, if unreliable, information on easily identifiable individuals. Before the Fair Credit Reporting Act, salacious unsubstantiated material could be included – and in fact, gossip was widely included in credit reports. EPIC has a FCRA page. The Consumer Data Industry Association, which represents the consumer reporting industry, also has a website with FCRA information.

The Fair Credit Reporting Act provides consumers the ability to view, correct, contest, and limit the uses of credit reports. The FCRA also protects the credit agency from the charge of negligent release in the case of misrepresentation by the requester. Credit agencies must ask the requester the purpose of a requested information release, but need to make no effort to

verify the truth of the requester's assertions. In fact, the courts have ruled that, "The Act clearly does not provide a remedy for an illicit or abusive use of information about consumers" (Henry v Forbes, 1976). It is widely believed that in order to avoid the FCRA, ChoicePoint was created by Equifax at which time the parent company copied all its records to its newly created subsidiary. ChoicePoint is not a credit reporting agency, and thus FCRA does not apply.

The Fair Debt Collection Practices Act similarly limits dissemination of information about a consumer's financial transactions. It prevents creditors or their agents from disclosing the fact that an individual is in debt to a third party, although it allows creditors and their agents to attempt to obtain information about a debtor's location. It limits the actions of those seeking payment of a debt. For example, debt collection agencies are prohibited from harassment or contacting individuals at work. The Bankruptcy Abuse Prevention and Consumer Protection Act of 2005 (which actually gutted consumer protections, for example in case of bankruptcy resulting from medical cost) limited some of these controls on debtors.

ECPA

The Electronic Communications Privacy Act (ECPA) establishes criminal sanctions for interception of electronic communication. However, the legislation has been criticized for lack of impact due to loopholes.

Computer security, privacy and criminal law

The following summarized some of the laws, regulations and directives related to the protection of information systems:

1970 U.S. Fair Credit Reporting Act

1970 U.S. Racketeer Influenced and Corrupt Organization (RICO) Act

1974 Family Educational Rights and Privacy Act (FERPA)

1974 U.S. Privacy Act

1980 Organization for Economic Cooperation and Development (OECD) Guidelines

1984 U.S. Medical Computer Crime Act

1984 U.S. Federal Computer Crime Act (strengthened in 1986 and 1994)

1986 U.S. Computer Fraud and Abuse Act (amended in 1986, 1994, 1996 and 2001)

1986 U.S. Electronic Communications Privacy Act (ECPA)

1987 U.S. Computer Security Act (Repealed by the Federal Information Security Management Act of 2002)

1988 U.S. Video Privacy Protection Act

1990 United Kingdom Computer Misuse Act

1991 U.S. Federal Sentencing Guidelines

1992 OECD Guidelines to Serve as a Total Security Framework

1994 Communications Assistance for Law Enforcement Act

1995 Council Directive on Data Protection for the European Union (EU)

1996 U.S. Economic and Protection of Proprietary Information Act

1996 Health Insurance Portability and Accountability Act (HIPAA) (requirement added in December 2000)

1998 U.S. Digital Millennium Copyright Act (DMCA)

1999 U.S. Uniform Computer Information Transactions Act (UCITA)

2000 U.S. Congress Electronic Signatures in Global National Commerce Act ("ESIGN")

2001 Uniting and Strengthening America by Providing Appropriate Tools to Restrict, Intercept and Obstruct Terrorism (USA PATRIOT) Act

2002 Homeland Security Act (HSA)

2002 Federal Information Security Management Act of 2002

Several US federal agencies have privacy statutes that cover their collection and use of private information. These include the Census Bureau, the Internal Revenue Service, and the National

Center for Education Statistics (under the Education Sciences Reform Act). In addition, the CIPSEA statute protects confidentiality of data collected by federal statistical agencies.

State-specific laws

Lawmakers in several states have proposed legislation to change the way online businesses handle user information. Among those generating significant attention are several Do Not Track legislation and the Right to Know Act (California Bill AB 1291). The California Right to Know Act, if passed, would require every business which keeps user information to provide its user a copy of stored information when requested. The bill faced heavy oppositions from trade groups representing companies such as Google, Microsoft, and Facebook, and failed to pass.

Arkansas

Arkansas has a biometric data privacy law.

California

On June 28, 2018 California legislature passed AB 375, the California Consumer Privacy Act of 2018, effective January 1, 2020. In November 2020, Proposition 24, also known as the California Privacy Rights Act, amended and expanded the CCPA. The law specifically protects employee data.

Florida

On June 6, 2023, Florida enacted Florida Senate Bill 262, effective July 1, 2024. It gives consumers the right to confirm whether businesses with over \$1 billion in gross annual revenue who derive more than half of their revenue from online ads collected data about them and control over the data, including correction and deletion. The law also prohibits

government agencies from asking a social media companies to censor content or remove users from its platform.

Illinois

On October 3, 2008, Illinois enacted the Biometric Information Privacy Act. The law was the first in the nation to regulate biometric data. The law requires private businesses to obtain consent to collect or disclose the biometric identifiers of consumers. The law also requires the data be securely stored and destroyed in a timely manner. The law specifically protects employee data.

New York

In 2021, New York enacted a commercial biometric data privacy law that requires businesses to conspicuously notify consumers of data collection. The law bars employers from collecting biometric data from employees.

Texas

In 2009, Texas enacted a consumer law requiring consent for biometric data for commercial use to be leased, sold, or disclosed. The law also requires the data be destroyed within one year of collection.

Washington

In 2017, Washington enacted a specific consumer biometric data privacy law covering commercial use.

On April 27, 2023, Washington enacted the My Health, My Data Act, effective March 31, 2024. The law was the first in the nation to regulate consumer health data not protected by HIPAA. The law requires companies to obtain prior authorization to obtain, share, or sell health data,

including data that can be used to infer or linked to health status, such as purchasing medications or digestion tracking. The law guarantees the right to withdraw consent and request deletion. The law also prohibits geo-fences around healthcare facilities.

South America

Brazil

Brazil's General Personal Data Protection Law (LGPD) became law on September 18, 2020. The law's primary aim is to unify 40 different Brazilian laws that regulate the processing of personal data. The bill has 65 articles and has many similarities to the GDPR.

"Safe Harbor" Privacy Framework

Unlike the U.S. approach to privacy protection, which relies on industry-specific legislation, regulation and self-regulation, the European Union relies on the comprehensive privacy legislation. The European Directive on Data Protection that went into effect in October 1998, includes, for example, the requirement to create government data protection agencies, registration of databases with those agencies, and in some instances prior approval before personal data processing may begin. In order to bridge these different privacy approaches and provide a streamlined means for U.S. organizations to comply with the Directive, the U.S. Department of Commerce in consultation with the European Commission developed a "safe harbor" framework. In order for the framework to be enforced, companies must publicly publish a privacy policy.

See also

Canadian privacy law

Center for Democracy and Technology

Data care

Data localization

Data sovereignty

Do Not Track legislation

Privacy Commissioner of Canada

Privacy International

Privacy laws of the United States

Right to be forgotten

References

Further reading

Warren S. and Brandeis L., 1890, "The right to privacy," Harvard Law Review, Vol. 4, 193-220.

Graham Greenleaf, Global Data Privacy Laws: 89 Countries, and Accelerating
<http://ssrn.com/abstract=2000034>